What actually reduced reconstruction risk

Research supplement - 19 October 2026. This extends the 18 October access-control and disclosure study. Its subject is reconstruction of a small pricing feature from permitted outputs, not cloning an entire SaaS product.

The useful finding

Keeping code on the server did not keep this simple pricing behaviour secret. With knowledge of the three-band rule family, the adaptive learner reconstructed all held-out prices after 24 exact observations on each of 16 randomly generated targets. A later exhaustive diagnostic confirmed the adaptive 24-query models also matched all 1,000 possible quantities on every target; that diagnostic includes queried inputs.

The strongest reduction tested came from **removing the arbitrary pricing oracle and returning exact prices only for server-approved quote requests**. Mean held-out exact match fell to **37.5%**, while both approved quote prices stayed exact. However, this removes unrestricted self-service estimation, and individual target accuracy still ranged from **21.9% to 89.8%**. It is a product restriction with measured benefit, not universal secrecy.

Results at a nominal budget of 24 requests

Numbers are mean fractions of 128 held-out quantities across 16 targets. For the initial five policies each accuracy column selects the better result of the uniform and adaptive learner separately for each target. This is an evaluation upper bound over the two tested methods, not a single learner selected in advance. Higher percentages mean **more successful reconstruction**.

Server policy	Exact matches	Predictions within 1%	Customer consequence
Exact minimal totals	100.0%	100.0%	Arbitrary quantities supported
Eight distinct quantities per tenant per day	96.4%	96.4%	Additional distinct quantities denied
Estimates rounded to GBP 1,000	10.2%	85.7%	Exact customer prices unavailable on this endpoint
Four approved catalogue quantities	71.6%	71.6%	Other quantities denied
Rounded estimates plus two exact approved quotes	43.1%	97.5%	Estimates remain general; exact quotes restricted
Approved quotes only - exploratory follow-up	37.5%	37.5%	General estimation removed; only two quotes supported

The final row uses one fixed two-observation learner and only four calls: two exact approved quotes and two denial probes. It was added after the initial results, reusing the same targets and holdouts. It is not a sixth pre-registered arm or a statistically established ranking of all possible defences. Its scoring domain includes quantities that this restricted product no longer supports; the supported quote outputs can still be memorised perfectly.

Three findings that change the advice

1. Rate limits may be far too generous for a simple function

With eight exact observations, the best of the two tested methods already achieved **97.3% mean held-out exact match**. That means “the ninth request is blocked” and “the feature is hard to reconstruct” are different claims.

The tests demonstrate that an eight-quantity **tenant** budget survives another principal and an endpoint alias. A negative control demonstrates that a **per-session** budget can be multiplied by using a second session. A simulated next day allows more queries under the tenant policy. The tested implementation is a single-process fixed-day counter, not a distributed or lifetime information limit. New tenants, collusion and account provisioning are outside this result.

2. Rounding can make the security score look better than the protection is

At 24 queries, rounding reduced mean exact match to 10.2%, but **85.7% of predictions were within 1%** of the hidden true price. At 64 queries, **98.4% were within 5%** and **90.7% within 1%** on average. The initial policy returning rounded estimates plus two exact quotes reached **99.3% within 1%** at 64 queries.

A client can combine observations from different quantities and endpoints. A small exact-match score alone is therefore a poor confidentiality success criterion. A useful imitation may not need identical pennies.

Rounding also had real customer cost: none of the 32 checked normal quotes was exact, and their mean absolute error was **GBP 297.34**. All other initial policies returned the correct total for both tested supported quantities on all 16 targets. That is a narrow functional check, not a usability study or proof that every customer workflow is preserved.

3. Workflow entitlement is stronger when it restricts the information itself

The approved-quote-only follow-up blocks arbitrary estimate requests and the alternate estimate route with 403. The server chooses quantity from its approved request record. Invented IDs, a client-selected quantity attached to a valid ID, and a supplied total are rejected. The two approved quotes remain exact.

All 16 direct HTTP runs preserved those two exact quotes and denied both general-query probes. Two additional real REA browser captures reproduced the same results. Mean absolute reconstruction error on the held-out domain was **GBP 3,006.66**; exact-match accuracy still reached **89.8%** on the easiest target. No claim of full prevention is justified.

The approval mechanism is **assumed**, not implemented as production commerce or entitlement. If a customer can create unlimited “approved” requests, the pricing oracle returns. A real design needs server-held ownership, permitted state transitions, limits on new approvals, consistent handling of duplicate actions, and equivalent enforcement on exports, retries, caches and alternate endpoints. Those deployment properties are recommendations, not results of this fixture.

What developers, architects and product managers should do

Role	Concrete change	Evidence to require
Developer	Keep private decisions off the client; return only required fields; bind sensitive outputs to server-owned requests; reject extra authority fields	No private implementation in delivered assets; denied arbitrary queries and aliases; correct approved outcomes
Architect	Model information disclosed by a whole workflow, across identities, endpoints and time; enforce shared budgets and entitlements consistently	Session/route reset tests, account-collusion assessment, distributed race tests, state-transition review and cache/export coverage
Product manager	Decide whether customers need a general calculator, coarse preview, or approved quote; define useful imitation tolerances	Reconstruction error at meaningful thresholds, supported workflow completion, customer precision loss, support demand and acceptable friction

For the highest practical protection, expose the **minimum sufficient result for a permitted business action**, and test the composition of everything else the same customer can observe. Keep private data, internal explanations and decision stages out of client responses when the product does not require them. Continue the original access-control protections; inference controls do not replace tenant isolation or authoritative server decisions.

This does not hide a public UI or prevent a competitor building a similar experience. Nor does it stop customers learning the exact information they are entitled to receive. Protecting a complete SaaS product also depends on private data, operational processes, integrations and service-side capabilities that this pricing benchmark does not model.

How this was measured

- **Initial design:** 16 fresh synthetic targets; five policies; two query methods; budgets 8, 24 and 64; 480 actual localhost HTTP model runs.

- **Initial REA validation:** ten browser captures using the same learner, two targets, five policies and budget 24. Captured browser observations and models matched the corresponding HTTP runs exactly.

- **Exploratory follow-up:** 16 HTTP models and two REA captures for the approved-quote-only policy, added after reviewing the initial results.

- **Total:** 496 HTTP runs plus 12 REA captures; 508 models scored. The HTTP runs are not claimed as REA executions.

- **Original holdouts:** 128 shared quantities per target, randomly selected after all 490 initial models were frozen. Inputs successfully queried by any initial learner for that target were excluded. This changes the scoring distribution near heavily probed boundaries; the separate full-domain diagnostic addresses fidelity across all inputs but includes training observations.

- **Prior knowledge:** learners were told the exact target family-three non-increasing integer unit-price bands. Thresholds and rates were provided only to the server and scorer. This is favourable to reconstruction and much narrower than a general SaaS feature.

- **Separation:** learners receive only query responses. There was no OS-enforced isolation or independent AI red team. The follow-up reused existing targets and holdouts, so it is explicitly exploratory.

- **Verification:** model and source hashes, freeze timestamps, every retained prediction, HTTP/REA parity, 178 browser result rows linked to distinct network responses, and 402 captured body digests were checked across the new REA scenarios. Overall incomplete-capture flags remain visible.

- **Tests:** ten additional control tests passed; together with the earlier 23 tests, the repository has 33 application tests. There are now 68 measured REA operations, including the original 56.

The strongest statistical unit is the **target**, not every prediction row. Sixteen synthetic targets are a small sample from one chosen family; 508 models are not 508 independent product security assessments. Per-target ranges, full predictions and failed protections are published.

Evidence and reproduction

See the experiment README, initial plan, exploratory plan, aggregate results, follow-up results, and the PDF supplement. Run both evidence verifiers to recalculate the scores and validate the retained captures.

The original 18 October white paper remains an immutable historical account of the baseline. This supplement supplies programmatic reconstruction measurements; independent blind agent and whole-product cloning studies remain unperformed.

Related primary sources

OWASP API6:2023 treats excessive automation of sensitive business workflows as a business-specific risk. It supports looking beyond isolated endpoint limits; it does not establish this study's numerical outcomes.

Tramèr et al., USENIX Security 2016 studied extracting machine-learning model behaviour through prediction APIs. That is related evidence that permitted outputs can disclose functionality, not validation of the pricing fixture or proof about all SaaS products. The measured results above come from this repository's own retained experiments.